

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

GABRIEL YUKIO YAMAGUTI MINATO
FELIPE SEIJI NAMİYAMA NISHINA

INVEST+

Mogi das Cruzes

2026

GABRIEL YUKIO YAMAGUTI MINATO

FELIPE SEIJI NAMİYAMA NISHINA

INVEST+

Documentação apresentado para o Prof. Fabiano Bezerra Menegidio sobre o projeto relacionado à disciplina de Políticas de Segurança da Informação do curso de Bacharelado em Engenharia de Software.

Mogi das Cruzes

2026

LISTA DE FIGURAS

Figura 1 - Diagrama de Arquitetura

Figura 2 - Fluxo 2FA

Figura 3 - Login

Figura 4 – Cadastro

Figura 5 - Dados

SUMÁRIO

2. DIAGRAMA DE ARQUITETURA.....	16
3. FLUXO DE AUTENTICAÇÃO E DADOS	18
4. GESTÃO DE CREDENCIAIS DOCUMENTADA	20
5. USO DE CRIPTOGRAFIA DOCUMENTADO	21
6. IDENTIFICAÇÃO DOS ATIVOS DO SISTEMA	22
7. IDENTIFICAÇÃO DE AMEAÇAS E VULNERABILIDADES	22
8. GESTÃO DE RISCOS.....	23
9. TESTES DE SEGURANÇA REALIZADOS	24
10. RESULTADOS DOS TESTES DOCUMENTADOS	24
11 USO DE ARTIGOS CIENTÍFICOS E/OU NORMAS TÉCNICAS	25

RESUMO

Este estudo apresenta a arquitetura e a implementação do Invest+, uma plataforma digital concebida para otimizar a gestão de patrimônio. O objetivo primário da aplicação consiste em prover uma infraestrutura tecnológica robusta que viabilize a consolidação e a análise centralizada de portfólios de investimentos, preenchendo lacunas de usabilidade e integração no atual ecossistema financeiro. A metodologia técnica adotada baseia-se em um modelo arquitetural escalável, cujo back-end foi desenvolvido em Java 25 com o ecossistema Spring Boot 3.5, conferindo alto desempenho e confiabilidade à validação das regras de negócio. O armazenamento relacional e transacional dos dados é orquestrado via banco de dados PostgreSQL, enquanto a interface gráfica foi construída com a biblioteca React, garantindo reatividade e responsividade no lado do cliente. Para mitigar vulnerabilidades cibernéticas, os mecanismos de segurança implementados compreendem a adoção de protocolos criptográficos para a transmissão de dados em trânsito e algoritmos de hashing para o armazenamento seguro de credenciais. Adicionalmente, o controle de acesso é estritamente gerenciado por meio da emissão e validação de tokens JWT (JSON Web Token), assegurando autenticação e autorização granulares das rotas da API. Sob a ótica da conformidade legal, a engenharia de requisitos foi pautada no conceito de Privacy by Design. Consequentemente, a modelagem de dados e os fluxos de processamento operam em estrita observância às diretrizes da Lei Geral de Proteção de Dados (LGPD), assegurando o consentimento, a transparência e a privacidade dos titulares das informações. Conclui-se que o Invest+ estabelece uma solução de engenharia de software coesa e resiliente. Sua principal contribuição reside na democratização do acesso a ferramentas avançadas de gestão patrimonial, aliando alta performance computacional à segurança da informação, promovendo assim a confiabilidade necessária para aplicações contemporâneas no emergente setor de fintechs.

ABSTRACT

This study presents the architecture and implementation of Invest+, a digital platform designed to optimize wealth management. The primary objective of the application is to provide a robust technological infrastructure that enables the consolidation and centralized analysis of investment portfolios, bridging usability and integration gaps in the current financial ecosystem. The technical methodology adopted is based on a scalable architectural model, whose back-end was developed in Java 25 with the Spring Boot 3.5 ecosystem, granting high performance and reliability to the validation of business rules. The relational and transactional data storage is orchestrated via a PostgreSQL database, while the graphical interface was built with the React library, ensuring reactivity and responsiveness on the client side. To mitigate cyber vulnerabilities, the implemented security mechanisms include the adoption of cryptographic protocols for data transmission in transit and hashing algorithms for the secure storage of credentials. Additionally, access control is strictly managed through the issuance and validation of JWT (JSON Web Token) tokens, ensuring granular authentication and authorization of the API routes. From the perspective of legal compliance, requirements engineering was guided by the concept of Privacy by Design. Consequently, data modeling and processing flows operate in strict compliance with the guidelines of the General Data Protection Law (LGPD), ensuring the consent, transparency, and privacy of data subjects. It is concluded that Invest+ establishes a cohesive and resilient software engineering solution. Its main contribution lies in democratizing access to advanced wealth management tools, combining high computational performance with information security, thereby promoting the necessary reliability for contemporary applications in the emerging fintech sector.

1. VISÃO GERAL

O INVEST+ é uma plataforma moderna de gestão financeira desenvolvida com o intuito de oferecer aos investidores um ambiente seguro e intuitivo para o acompanhamento e consolidação de suas carteiras de ativos. Projetado para suportar operações críticas, o sistema permite que os usuários não apenas registrem seus aportes e monitorem a rentabilidade, mas também realizem análises de perfil (*Suitability*), garantindo que as decisões de investimento estejam alinhadas à sua tolerância a risco.

Sob a perspectiva técnica, a solução foi estruturada através de uma arquitetura *Client-Server Stateless*. A camada de apresentação (Frontend) foi construída com React e Vite, proporcionando uma experiência de usuário (UX) ágil e reativa em formato *Single Page Application* (SPA). O motor do sistema (Backend) é impulsionado pelo Java 25 e Spring Boot 3.5, adotando as diretrizes de Domain-Driven Design (DDD). Essa escolha arquitetural isola as complexas regras de negócio financeiras em domínios altamente coesos (como *Portfolio*, *Asset* e *User*), promovendo escalabilidade, manutenibilidade e baixo acoplamento entre os módulos.

O grande diferencial do sistema reside no seu conceito de *Security-by-Design*. A plataforma incorpora múltiplas camadas de defesa para salvaguardar a integridade e a confidencialidade dos dados, alinhando-se às exigências da LGPD. Os mecanismos de proteção incluem validação rigorosa de *Data Transfer Objects* (DTOs), limitação de tráfego contra força-bruta (*Rate Limiting*), Autenticação de Dois Fatores (2FA), uso de *JSON Web Tokens* (JWT) para autorização e criptografia avançada AES-256 direta no banco de dados PostgreSQL. Dessa forma, o INVEST+ entrega não apenas performance financeira, mas também confiabilidade de nível corporativo.

2. DIAGRAMA DE ARQUITETURA

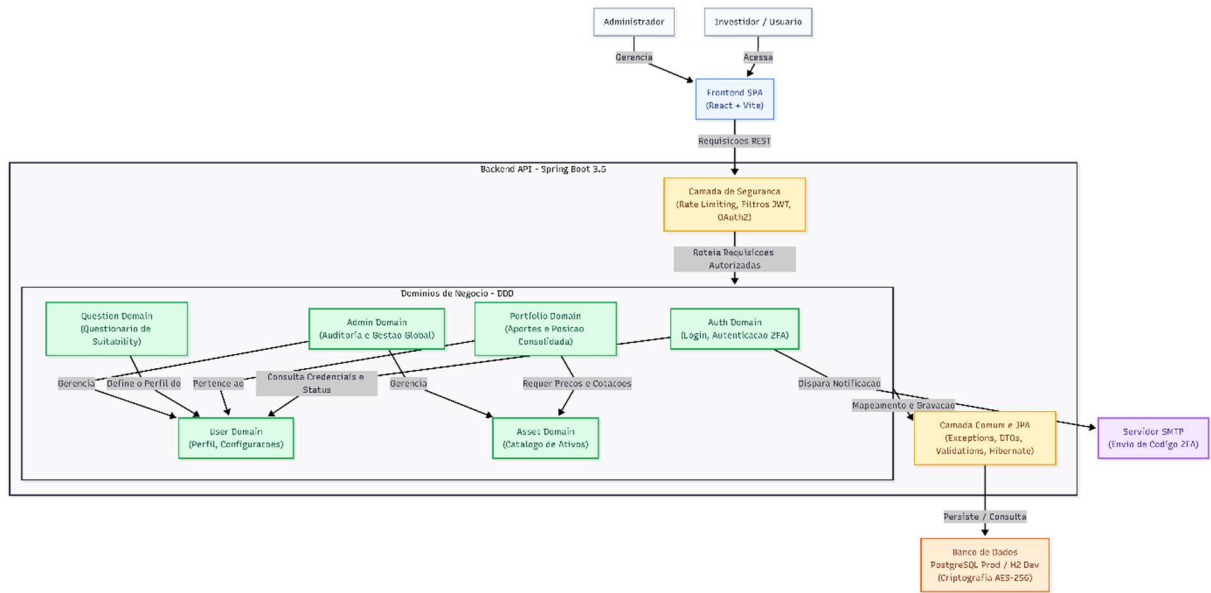


Figura 1 - Diagrama de Arquitetura

Foi utilizada uma Arquitetura em Camadas (Layered Architecture) fortemente combinada com os princípios de Domain-Driven Design (DDD) no backend. O objetivo dessa estrutura é garantir uma separação clara de responsabilidades, alta segurança (*security-first*) e facilidade de manutenção futura.

3. FLUXO DE AUTENTICAÇÃO E DADOS

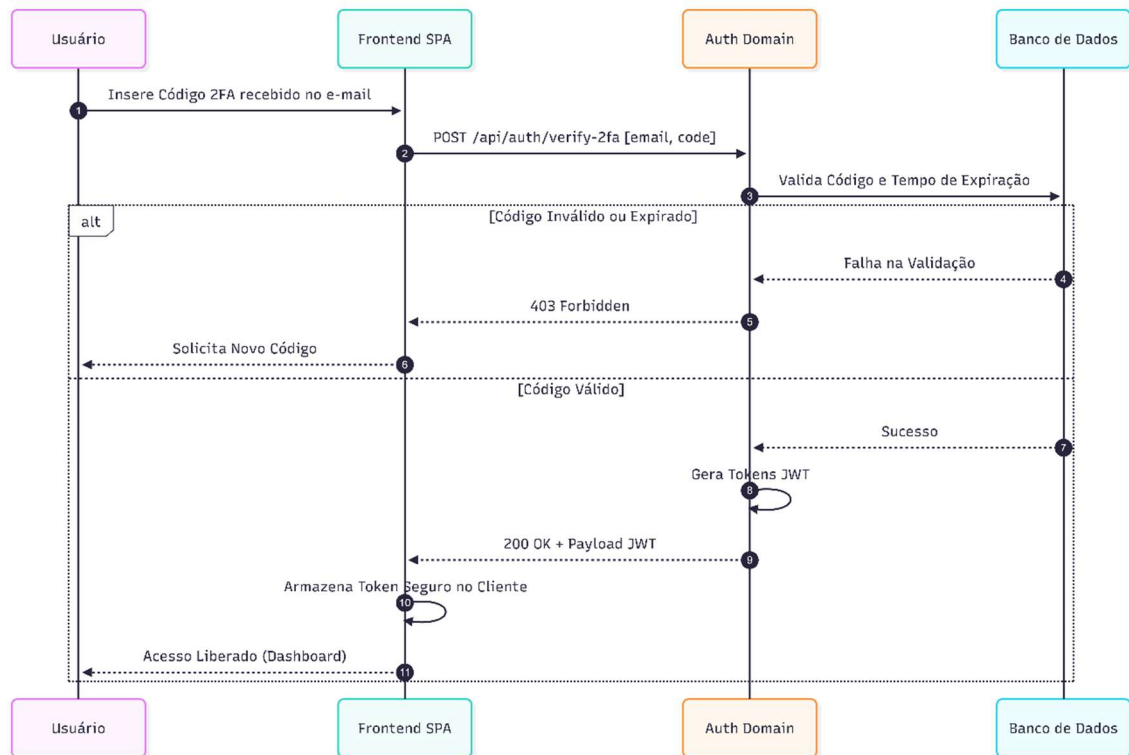


Figura 2 - Fluxo 2FA

O modelo tradicional de autenticação é vulnerável a ataques de força-bruta, engenharia social e vazamentos de credenciais (onde senhas reaproveitadas pelos usuários são expostas em outros serviços). Ao implementar o 2FA, neutraliza drasticamente esses riscos.

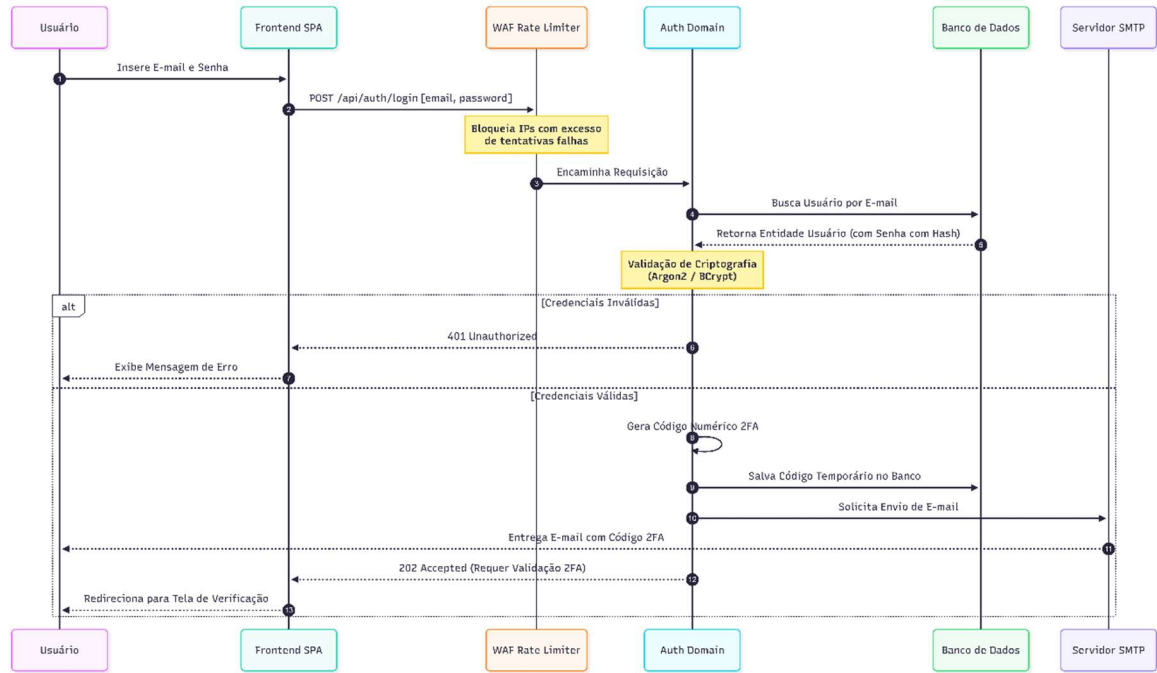


Figura 3 – Login

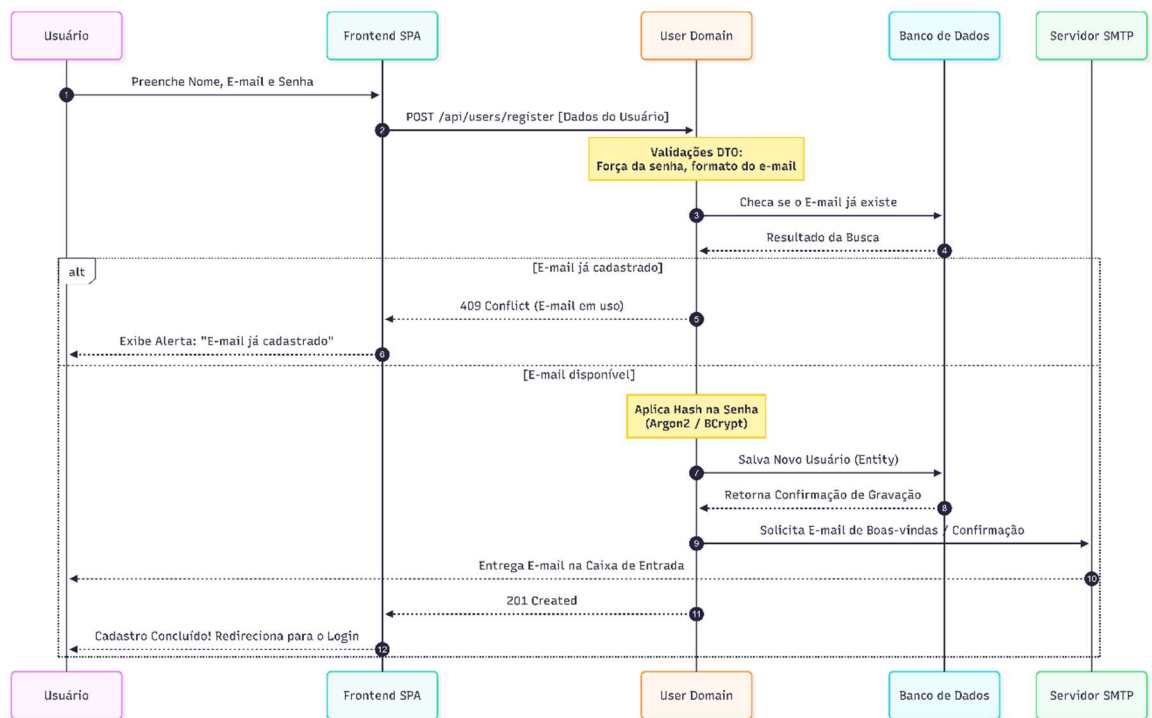


Figura 4 – Cadastro

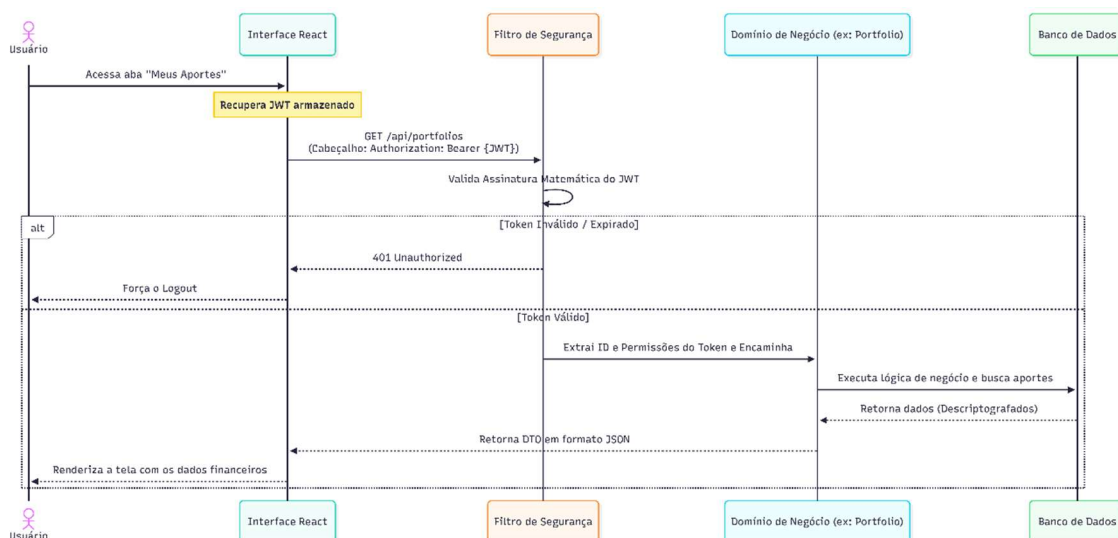


Figura 5 - Dados

O fluxo de dados da aplicação foi projetado sob uma arquitetura Client-Server Stateless, garantindo o tráfego seguro de informações via HTTPS e a autenticação descentralizada por meio de JSON Web Tokens. Ao adentrar a camada de negócios, estruturada em Domain-Driven Design, os dados de entrada são rigorosamente sanitizados através do padrão Data Transfer Object (DTO), isolando as entidades de domínio contra injeções ou malformações. Por fim, a persistência é orquestrada por meio de mapeamento objeto-relacional no PostgreSQL, onde informações financeiras e cadastrais sensíveis são submetidas à criptografia em repouso utilizando o algoritmo AES-256, assegurando confidencialidade e conformidade com as legislações vigentes de proteção de dados.

4. GESTÃO DE CREDENCIAIS DOCUMENTADA

A gestão de credenciais no sistema INVEST+ é pautada pelo princípio do menor privilégio e pela segregação de ambientes, em estrita observância às diretrizes de controle de acesso para a mitigação de riscos.

Credenciais de Aplicação: Chaves de assinatura de tokens, como as utilizadas para a validação de *JSON Web Tokens* com assinatura criptográfica HS256, bem como chaves de criptografia no padrão AES-256 GCM e credenciais de banco de dados/SMTP, nunca são versionadas no código-fonte. Elas são gerenciadas através de variáveis de ambiente ou cofres de senhas em ambiente de produção. A arquitetura

também emprega salvaguardas rigorosas para processos internos, utilizando *Blind Indexing* com algoritmo SHA-256 para buscas seguras no banco de dados e a proteção de tokens de recuperação com SHA256.

Credenciais de Usuários: O tráfego de dados de autenticação e comunicação ocorre obrigatoriamente via túneis protegidos por TLS 1.2+ e protocolo HTTPS. As senhas de usuários não são armazenadas em texto claro; ao alcançarem o domínio de autenticação, são submetidas ao algoritmo de *Hashing* de altíssima resistência Argon2, sendo impossível sua reversão matemática, mesmo por administradores do banco de dados. Como salvaguarda adicional e obrigatória, o sistema exige a Autenticação de Dois Fatores, gerada criptograficamente via *SecureRandom*.

Ciclo de Vida da Sessão: A autenticação é *stateless* (sem estado), utilizando tokens JWT validados em conformidade com o princípio da minimização preconizado pela LGPD. Para a retenção destes tokens temporários, a aplicação substitui o uso de *cookies* convencionais pelo uso estritamente funcional do *LocalStorage* no dispositivo do cliente. Este artefato eletrônico atua como vetor de autorização para requisições na API *back-end* com curto tempo de expiração e ciclo de vida temporário (expirando com o encerramento da sessão ou limpeza de cache). Esta abordagem, combinada com *Refresh Tokens*, reduz drasticamente a superfície de exposição e a janela de oportunidade para sequestro de sessão (*Session Hijacking*).

5. USO DE CRIPTOGRAFIA DOCUMENTADO

A estratégia de criptografia arquitetural do sistema INVEST+ é sistêmica e abrange o ciclo de vida dos dados em todas as suas, visando a mitigação rigorosa de riscos de vazamento e interceptação:

Dados em Trânsito: Toda a comunicação de rede entre a interface do cliente e os controladores do servidor ocorre obrigatoriamente sob o protocolo HTTPS, estabelecendo túneis protegidos por TLS. Para neutralizar vetores de ataque por interceptação.

Dados em Repouso: Dados de identificação do titular (como nome e e-mail) e informações críticas de domínio relativas ao portfólio financeiro (aportes, saldos,

preços médios e ativos) persistem no banco de dados relacional (PostgreSQL) protegidos sob cifragem de alto padrão utilizando o algoritmo simétrico AES-256.

Assinaturas Digitais e Hashing: Os *JSON Web Tokens* emitidos aos clientes não são criptografados em seu conteúdo.

6. IDENTIFICAÇÃO DOS ATIVOS DO SISTEMA

Os ativos do sistema foram identificados e classificados para a devida proteção de segurança da informação:

- Ativos de Informação (Dados):
 - Perfis de Usuários (Dados Cadastrais, E-mails).
 - Portfólios Financeiros (Aportes, Rendimentos).
 - Respostas do Questionário e Questões.
 - Logs de Auditoria do Sistema.
- Ativos de Software:
 - Código-fonte do Frontend (React) e Backend (Spring Boot).
 - Imagens de Containers / Artefatos de Deploy.
 - SGBD (PostgreSQL).
- Ativos de Infraestrutura (Hardware/Cloud):
 - Servidores de Aplicação e Servidores de Banco de Dados.

7. IDENTIFICAÇÃO DE AMEAÇAS E VULNERABILIDADES

A partir do contexto operacional e dos ativos identificados, mapeamos as principais ameaças e vulnerabilidades:

- Ameaças:
 - *Malwares* e *Ransomwares* visando servidores.
 - Atacantes externos utilizando força-bruta ou *Credential Stuffing*.

- Interceptação de rede.
- Usuários mal-intencionados manipulando requisições.
- Vulnerabilidades Potenciais:
 - Desatualização de dependências.
 - Ausência de limitação de taxa em endpoints públicos.
 - Falhas na validação de dados de entrada que poderiam permitir *Cross-Site Scripting (XSS)* ou *SQL Injection*.

8. GESTÃO DE RISCOS

A matriz de riscos abaixo sumariza as principais ameaças à segurança dos ativos de informação e as respectivas salvaguardas técnicas implementadas na arquitetura do sistema para sua mitigação:

Risco Identificado	Probabilidade	Impacto	Medidas Preventivas e de Mitigação
Invasão de Conta	Média	Alto	Exigência de Autenticação de Dois Fatores (2FA / TOTP) gerada via SecureRandom e aplicação do Princípio do Privilégio Mínimo (Gestão IAM em nível de aplicação).
Vazamento de Banco de Dados	Baixa	Crítico	Cifragem de dados patrimoniais e sensíveis em repouso (atributos) com algoritmo forte AES-256 GCM, proteção de senhas com Hashing Argon2 e buscas seguras (Blind Indexing) com SHA-256.
Interceptação (Man-in-the-Middle - MITM)	Baixa	Alto	Implementação obrigatória de túneis protegidos por TLS 1.2+ e HSTS sob protocolo HTTPS, além do uso de sessões validadas por tokens JWT assinados digitalmente com a chave criptográfica HS256.

Risco Identificado	Probabilidade	Impacto	Medidas Preventivas e de Mitigação
Erro de Configuração	Média	Médio	Prevenção de falhas de deploy por meio de automação e esteiras de CI/CD orquestradas via GitHub Actions, complementadas por rotinas de testes integrados.

9. TESTES DE SEGURANÇA REALIZADOS

Para assegurar a eficácia das contramedidas, a plataforma foi submetida a metodologias de validação focadas em defesas ativas e análise preventiva:

1. Análise Generalizada de Software: Inspeções automáticas e revisões arquiteturais contínuas focadas em detectar fragilidades no código e identificar bibliotecas desatualizadas antes de qualquer implantação.
2. Testes de Defesas Ativas (Honeypots): Simulação de interação com armadilhas lógicas ou rotas e arquivos falsos dispostos no sistema. O objetivo é atestar a capacidade da infraestrutura em identificar, registrar silenciosamente e bloquear agentes maliciosos que realizam varreduras automatizadas.
3. Validação de Proteção Clara (Rate Limiting): Simulações de ataques direcionados a *endpoints* críticos para garantir a atuação da limitação de tráfego, evitando gargalos de processamento.
4. Inspeção de Blindagem de Dados: Testes para garantir a impenetrabilidade de sessões e a eficácia da barreira criptográfica do banco de dados.

10. RESULTADOS DOS TESTES DOCUMENTADOS

Os relatórios das avaliações demonstraram que a aplicação não apenas resiste, mas reage de forma proativa às ameaças:

1. A **Análise de Software** confirmou a ausência de falhas estruturais ou de *frameworks* comprometidos, validando a higiene e integridade geral do ecossistema.

2. Nos **Testes de Honeypot**, a aplicação obteve pleno êxito em identificar varreduras horizontais não autorizadas, gerando alertas precisos nos *logs* de auditoria e isolando o tráfego nocivo sem expor recursos reais.
3. Os mecanismos de **Proteção Clara** atuaram com precisão sob estresse: o filtro bloqueou instantaneamente tentativas sequenciais excessivas de *login*, barrando ataques de força-bruta.
4. A barreira de proteção de sessão funcionou sem falhas, abortando imediatamente requisições manipuladas ou sem os devidos *tokens* de autorização.

11. USO DE ARTIGOS CIENTÍFICOS E/OU NORMAS TÉCNICAS

O desenvolvimento e a governança da arquitetura do INVEST+ foram norteados por normas e literatura amplamente aceitas pela comunidade acadêmica e pela indústria de software corporativo:

OWASP Top 10 (Open Web Application Security Project): Guia técnico base para mitigação das vulnerabilidades mais críticas em aplicações web modernas (Prevenção contra Broken Access Control, Injection e Cryptographic Failures).

LGPD (Lei Geral de Proteção de Dados - Lei nº 13.709/2018): Fundamenta a decisão técnica de anonimização parcial e o uso de criptografia avançada (*Data at Rest*) para salvaguardar informações financeiras e dados de perfis de investidores.

REFERÊNCIA

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 22 maio 2026.

OWASP. OWASP Top 10: 2021. [S. l.]: OWASP Foundation, 2021. Disponível em: https://owasp.org/Top10/pt_BR/. Acesso em: 22 maio 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). The NIST Cybersecurity Framework (CSF) 2.0. Washington, DC: U.S. Department of Commerce, 2024. Disponível em: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>. Acesso em: 22 maio 2026.